

Section C : Security Validation and Vulnerability Assessment

Q3. Structural Vulnerability Examination using OWASP ZAP

1. Importance of Security-Oriented Validation

Security-oriented validation ensures that software systems are protected against cyber threats and vulnerabilities before deployment. It helps maintain confidentiality, integrity, and availability of data while reducing the risk of attacks, data breaches, and financial loss.

2. Three Vulnerabilities

a) SQL Injection

Occurs when attackers insert malicious SQL queries into input fields to manipulate databases.

Impact: Unauthorized data access, deletion, or modification.

b) Cross-Site Scripting (XSS)

Occurs when malicious scripts are injected into web pages viewed by users.

Impact: Session hijacking, cookie theft, and malicious redirects.

c) Broken Authentication

Occurs when authentication mechanisms are poorly implemented.

Impact: Attackers may gain unauthorized access to user accounts.



Automated Scan



This screen allows you to launch an automated scan against an application - just enter its URL below and press 'Attack'.

Please be aware that you should only attack applications that you have been specifically given permission to test.

URL to attack:	https://github.com/digininja/DVWA?utm_source=chatgpt.com	Select...
Scan Policy:	Dev Standard	
Use traditional spider:	☒	
Use ajax spider:	If Modern	with Chrome

History Search Alerts Output Spider +				
New Scan Progress: 0: https://github../digininja/DVWA 8% Current Scans: 1 URLs Found: 5631 Nodes Added: 241 Export				
URLs	Added Nodes	Messages		
Processed	Method	URI	Flags	
●	GET	https://github.githubassets.com/assets/global-banner-disable-7d723d7ca7c71...	Out of Scope	
●	GET	https://github.githubassets.com/assets/MonaSansVF-wdth-wght-opsz-902d64c...	Out of Scope	
●	GET	https://github.githubassets.com/assets/site-9e580c38ab6535be.css	Out of Scope	
●	GET	https://github.githubassets.com/assets/error-8456319999cfe62d.css	Out of Scope	
●	GET	https://github.com//tarball		
●	GET	https://github.com//tarball/?query-builder-test=ZAP		
●	POST	https://github.com/session		
●	GET	https://github.com/search?q=ZAP		
●	GET	https://github.com/login?return_to=https%3A%2F%2Fgithub.com%2F%2A%2F...		
●	GET	https://github.com/signup?ref_cta=Sign+up&ref_loc=header+logged+out&ref_...		

History Search Alerts Output Spider +

General

Downloading https://github.com/zaproxy/zap-extensions/releases/download/retire-v0.58.0/retire-release-0.58.0.zap to C:\Users\HF\ZAP\plugin\retire-release-0.58.0.zap
 Replacing add-on Retire.js version 0.57.0
 Uninstalled add-on Retire.js version 0.57.0
 Installing new add-on Retire.js version 0.58.0
 Finished installing new add-on Retire.js version 0.58.0

History Search Alerts Output Spider +

Alerts (16)

- > Application Error Disclosure
- > CSP: Failure to Define Directive with No Fallback (Systemic)
- > CSP: style-src unsafe-inline (Systemic)
- > Sub Resource Integrity Attribute Missing (Systemic)
- > Cookie No HttpOnly Flag (3)
- > Cross-Domain JavaScript Source File Inclusion (Systemic)
- > Information Disclosure - Debug Error Messages (2)
- > Strict-Transport-Security Header Not Set (Systemic)
- > Timestamp Disclosure - Unix (Systemic)
- > X-Content-Type-Options Header Missing (4)
- > Authentication Request Identified (44)
- > CSP: Header & Meta (Systemic)
- > Modern Web Application (Systemic)

Full details of any selected alert will be displayed here.

You can manually add alerts by right clicking on the relevant line in the history and selecting 'Add alert'.

You can also edit existing alerts by double clicking on them.

Link:

<https://github.com/Hiba-Zahid55/Workflow>

Mitigation Actions

Vulnerability	Mitigation
XSS	Sanitize user input
SQL Injection	Use parameterized queries
Missing Headers	Configure security headers

Risk Register

Risk ID	Risk Description	Source Evidence	Probability	Impact	Risk Level	Mitigation
VR-01	XSS vulnerability	ZAP Report	High	High	Critical	Input sanitization
VR-02	Missing security headers	Scan Result	Medium	Medium	Moderate	Add security headers
VR-03	SQL Injection	ZAP Report	High	High	Critical	Use prepared statements